

Board Deck Draft V1

Purpose

This is a first working draft of Deliverable A. It is intentionally written so the team can refactor individual slides later as governance, cyber, operational, and regulatory inputs arrive.

Cover Slide

Title

Nordhaven–LumaPay AI Risk Review

Subtitle

Board-level view of acquisition-related AI governance, operational, and cyber risk

Prepared By

Slide 1: Executive Summary

Headline

Nordhaven is acquiring a high-growth AI-intensive fintech whose control maturity is materially below Nordhaven's existing risk baseline.

Key Message

The transaction creates immediate AI risk not because LumaPay lacks value, but because Nordhaven inherits regulated credit models, customer-facing LLM workflows, agentic tooling, third-party AI dependence, and copied live PII in test before governance and security controls are aligned.

Top Board Risks

- Live customer PII has been copied into lower environments without masking, creating immediate privacy, confidentiality, and regulatory exposure.
- LumaCredit-EU appears to operate as a high-risk credit-decision system with

Slide 2: Why This Deal Is An AI Risk Stress Test

Headline

This is not a standard technology integration; it is the acquisition of an AI estate with regulatory, operational, and cyber exposure embedded in the business model.

Core Points

- LumaPay's AI assets are central to product delivery in BNPL , SME lending, customer servicing, and fraud controls.
- Traditional diligence would not fully surface model lineage, prompt flows, MCP-connected tool risk, drift exposure, or incomplete governance evidence.
- The interim integration state increases attack surface, duplicates control boundaries, and introduces uncertainty over ownership, approval rights, and escalation paths.
- Cross-border data flows into US-hosted environments increase scrutiny under GDPR , UK GDPR , and related transfer obligations.

Slide 3: LumaPay At A Glance

Headline

LumaPay is small, developer-heavy, and product-led, with strong AI exposure but thin control capacity.

Current-State Profile

- 200 employees
- 100 developers
- 5 platform engineers
- no dedicated security team
- no dedicated GRC team
- two AWS accounts: test and production
- no CSPM , DSPM , or modern AI security tooling

Slide 4: AI Systems In Scope

Headline

The inherited AI estate contains four distinct systems, each with a different risk profile and regulatory significance.

Systems

- LumaCredit-EU

Credit-decision model stack for lending outcomes. Most exposed to high-risk AI governance, explainability, drift, and data quality requirements.

- LumaAssist Chat

Customer-facing LLM assistant. Most exposed to prompt injection, data leakage, and over-broad MCP-connected access.

- AutoUnderwriter Agent

Agentic internal workflow combining model reasoning with underwriting tool access.

Slide 5: Top 6 AI Risks

Headline

The most material risks are inherited-state control failures that can create customer harm, regulatory breach, or operational disruption before target-state integration is complete.

Risk	Why It Matters	Lifecycle Stage	Primary Reference
R-01 Unredacted PII in test	Live personal data is already outside intended production boundaries, creating immediate privacy and security exposure.	Data / Develop	GDPR , UK GDPR , ISO/IEC 27001
R-02 High-risk AI	Nordhaven may inherit a credit-decision system	Design /	EU AI Act , ISO/IEC

Slide 6: Pre-Close Due-Diligence Priorities

Headline

Pre-close diligence should focus on the evidence gaps most likely to affect legal exposure, service continuity, and regulator defensibility.

Priority Evidence Requests

- Environment inventory and proof of whether live PII exists in test or other lower environments
- LumaCredit-EU model documentation, validation evidence, and ownership records
- MCP inventory, tool permission matrix, and approval model for LLM and agent workflows
- Logging, trace-retention, and redaction controls for prompts and AI observability data
- Vendor contracts, assignment rights, and fallback assumptions for FraudShield and other critical suppliers

Slide 7: Governance, Operational, And Cyber Stress Test

Headline

The transaction should be viewed through three lenses simultaneously because failures in one area cascade into the others.

Governance Lens

- Weak AI registry discipline
- fragmented ownership
- incomplete documentation
- inconsistent approval and escalation paths

Operational Lens

- drift risk in credit and fraud systems
- orphaned knowledge in a small engineering team

Slide 8: Interim AI Risk Appetite And Tolerance

Headline

Nordhaven should operate with low or very low appetite for inherited AI risks that affect regulated decisions, customer treatment, or unbounded third-party dependence.

Property	Interim Appetite	Tolerance Direction
Opacity	Low	No high-impact system should remain materially undocumented beyond 60 days post-close.
Autonomy	Very low	0 autonomous high-impact credit or customer actions without human approval.
Dependency	Low	All critical AI vendors and MCP-connected tools must have owners, inventory entries, and fallback assumptions within 60 days

Slide 9: 100-Day AI Integration Plan

Headline

Nordhaven can materially reduce inherited AI risk in the first 100 days without waiting for full platform harmonization.

Day 0–30

- stop further copying of live PII
- inventory AI systems, dependencies, and MCP tools
- establish interim AI governance forum
- reduce high-risk MCP permissions

Day 31–60

- classify LumaCredit-EU formally as high-risk AI
- build minimum evidence pack for credit decisioning

Slide 10: Board Decisions And Escalation Asks

Headline

The Board should leave this review with explicit ownership, funding, and escalation decisions.

Requested Decisions

- Approve the interim AI governance forum and decision-rights model.
- Approve urgent remediation funding for copied live PII in test .
- Endorse high-priority control uplift for LumaCredit-EU , LumaAssist Chat , and AutoUnderwriter Agent .
- Require monthly inherited-state AI risk reporting until material gaps are closed.
- Require pre-close legal review of critical AI vendor contracts and fallback assumptions.

Editing Notes For The Team

- Replace placeholder phrasing with workstream-specific detail as governance, cyber, and regulatory inputs arrive.
- Keep slide 1, slide 5, slide 8, and slide 9 tightly aligned; those are the backbone of the board story.
- If the deck needs to be shortened, preserve slides 1, 5, 8, 9, and 10 first.